

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

«Zloy»: новая инфраструктура банковского трояна Mamont под видом гос-мессенджера МАХ и «блокировки полицией»

Mamont • Android Banking Trojan • Telegram C2 • MaaS • Russia • Gosuslugi

Параметр	Значение
Период	Активна как минимум с мая 2026, обнаружена 19 июля 2026
Классификация	Android-банкер (семейство Mamont), сбор SMS/push-кодов, эксфильтрация через Telegram
Уровень угрозы	ВЫСОКИЙ
Атрибуция	Приватный билдер "zloy" (Mamont-вариант), multi-tenant MaaS-платформа с отдельными "командами"-арендаторами
Цель	Пользователи Android в России: клиенты крупных банков, портал Госуслуги, мессенджеры
Статус	Кампания активна; минимум 112 связанных файлов и 3 адреса C2 на момент публикации

1. Краткое заключение

19 июля 2026 года при рутинном мониторинге публичного потока образцов в песочнице Triage был обнаружен Android-APK, маскирующийся под видеофайл с помощью греческих омографов в имени («Μαχ_video.apk»). Автоматическая классификация не смогла определить семейство вредоносного ПО (family: none) — как показал последующий анализ, из-за целенаправленного приёма обхода статических парсеров в самом APK. Реверс-инжиниринг показал, что это новый, ранее не задокументированный вариант известного российского банковского трояна Mamont, собранный приватным билдером, который сам себя маркирует как «zloy».

Mamont — банковский троян для Android, нацеленный исключительно на российских пользователей; впервые задокументирован в 2023 году, с тех пор его активность выросла (по данным «Лаборатории Касперского» — в 36 раз год к году, около миллиона затронутых устройств за январь–август 2025), несмотря на аресты трёх подозреваемых в его разработке в России. Обнаруженная инфраструктура не пересекается ни по одному индикатору с ранее опубликованным нами отчётом от 15 марта 2026 года о кампании Mamont под видом «Фото ДТП» — это отдельный, самостоятельный кластер того же семейства.

Ключевые новые технические находки: (1) приватный билдер «zloy» с multi-tenant архитектурой — вредонос содержит поле «team», указывающее на принадлежность конкретной сборки арендатору MaaS-платформы; (2) целенаправленный приём обхода статического анализа — в ZIP-контейнере APK у файла AndroidManifest.xml подделан флаг «strong encryption», из-за которого стандартные zip-парсеры (включая используемые в автоматических песочницах) отказываются его читать, тогда как штатный парсер Android этот флаг игнорирует; (3) эксфильтрация украденных данных ведётся в Telegram по восьми отдельным каналам, разделённым по типу данных (SMS, push-уведомления, список приложений, статус онлайн и др.); (4) приманка мимикрирует под российский государственный мессенджер МАХ (реальный сайт max.ru используется как декоративная веб-страница поверх фонового вредоносного сервиса).

2. Обнаружение и обход статического анализа

Образец был найден при поиске недавних Android-сэмплов с высоким score, но без атрибуции семейства. Первая попытка декодировать APK инструментами apktool и Python zipfile завершилась ошибкой парсинга ZIP-контейнера. Анализ на уровне байт показал, что у записи AndroidManifest.xml в локальном заголовке ZIP выставлен бит общего назначения «strong encryption» (bit 6) и подменено поле метода сжатия — при этом запись в центральном каталоге ZIP (который использует системный парсер Android) остаётся корректной и указывает на обычное DEFLATE-сжатие без шифрования.

Это классический приём антианализа: инструменты, которые строго валидируют локальный заголовок записи (apktool, стандартные библиотеки zip), отказываются читать манифест, тогда как штатный парсер пакетов Android читает данные из центрального каталога и не проверяет соответствие с локальным заголовком, поэтому устанавливает APK без проблем. После восстановления корректного заголовка (по данным из центрального каталога) манифест и код декомпилировались штатно, что и позволило провести приведенный ниже анализ.

3. Целевой список и возможности

В манифесте явно перечислен список пакетов, наличие которых на устройстве проверяется через механизм <queries> (Android 11+ package visibility). Список включает мобильные приложения крупнейших российских банков, портал государственных услуг и основные мессенджеры:

- Банки: Сбербанк, Альфа-Банк, Тинькофф, ВТБ, Совкомбанк (Халва), Газпромбанк, МТС Банк, Ozon Банк, Росбанк, ОТП Банк.
- Госуслуги (ru.gosuslugi.mobile) — потенциальный вектор кражи доступа к государственным сервисам и связанной двухфакторной аутентификации.
- Мессенджеры: Telegram, VK, Одноклассники и MAX (ru.oneme.app) — российский государственный мессенджер, продвигаемый как замена зарубежным сервисам; именно под него мимикрирует сама приманка.

Запрашиваемые разрешения и заявленные компоненты дают вредоносу полный контроль над SMS-каналом устройства: перехват входящих SMS (в т.ч. в роли SMS-приложения по умолчанию), чтение и отправка SMS, обработка WAP Push, чтение контактов и номера телефона, исходящие звонки.

Дополнительно зарегистрирован NotificationListenerService, позволяющий перехватывать push-уведомления любых приложений (включая одноразовые коды из банковских приложений) без необходимости SMS-доступа. В ресурсах приложения найден включённый экран «Придумайте PIN-код» — классический overlay для кражи PIN/пароля под видом настройки самого приложения.

Персистентность реализована через широкий набор широковещательных приёмников на события перезагрузки, разблокировки экрана и изменения режима энергосбережения — включая приёмники под специфичные для MIUI (Xiaomi), Huawei, Samsung и Transsion события энергосбережения, что указывает на целенаправленную адаптацию под популярные в России бренды устройств с агрессивным управлением фоновыми процессами.

4. Приватный билдер «zloy» и MaaS-архитектура

Весь код вредоносной функциональности расположен в неймспейсе «zloy» (пакеты zloy.*, zloy.c2.*, zloy.core.*), а в строковых ресурсах явно присутствует идентификатор сборки zloy_build_id со значением вида «zloy-build-25626619» — это указывает на приватный инструмент сборки, которым, вероятно, пользуется не только один оператор.

В ресурсах и сетевом протоколе присутствует поле team (у проанализированного образца — «001»), которое передаётся при регистрации устройства на C2. Найденная позднее в публичном источнике информация об абузе на соседнем адресе того же хостинг-провайдера подтверждает эту гипотезу напрямую: там указан другой номер команды («Bombo»), другой позывной оператора («Muertos 2.0») и другое имя пакета — то есть один и тот же билдер и одна и та же инфраструктура хостинга обслуживают минимум двух независимых операторов/арендаторов одновременно. Это указывает на модель malware-as-a-service, а не на единичный самостоятельный проект.

Протокол C2 построен на WebSocket-соединении (ws://) с JSON-сообщениями типов register/auth/evt/response. Регистрация устройства идёт открытым текстом (hwid, team, метаданные устройства) через HTTP POST на /api/v1/register; в ответ C2 выдаёт сессионный ключ, зашифрованный статическим секретом сборки. Все последующие события (украденные данные, статусы) шифруются этим сессионным ключом через AES-256-GCM перед отправкой. Крупные файлы (например, дампы SMS) загружаются отдельным HTTP-эндпоинтом /api/upload с заголовками X-Team/X-Hwid, что подтверждает мультиарендную модель на уровне транспортного протокола.

В строковых ресурсах образца обнаружены восемь идентификаторов чатов Telegram, разделённых по типу передаваемых данных: административный канал, список установленных приложений, архив, канал запуска, статус «онлайн», push-уведомления, SMS-push и текстовые данные. Это соответствует публично задокументированному для Mamont паттерну — эксфильтрации украденных данных напрямую в Telegram, что затрудняет блокировку на сетевом уровне (легитимный трафик Telegram API).

5. Инфраструктура и распространение

Все три обнаруженных C2-адреса размещены у одного хостинг-провайдера — PLAY2GO INTERNATIONAL LIMITED (ASN 215439, зарегистрирован в Великобритании, физическое размещение — Франкфурт-на-Майне, Германия). Сетевой блок 31.76.10.0/24 зарегистрирован 3 июня 2026 года — инфраструктура свежая. На VirusTotal с одним из адресов (31.76.10.34:8443) связано не менее 112 уникальных файлов, что указывает на активную, продолжающуюся кампанию, а не единичный образец.

Распространение ведётся через одноразовые лендинговые страницы на бесплатном хостинге Vercel с URL, тематически оформленными под «полицию» (police*.vercel.app, в т.ч. поддомен с явным русскоязычным таргетингом «2026rupolice.vercel.app») — типичный для этой ниши фрода сценарий социальной инженерии «ваш аккаунт заблокирован правоохранительными органами, установите приложение для разблокировки». Часть файлов в кластере C2 имеет чисто числовые имена, характерные для идентификаторов файлов Telegram (file_id), что говорит о параллельном распространении через Telegram-каналы/боты — тот же канал, что используется и для эксфильтрации.

6. Индикаторы компрометации (IOC)

Значения обезврежены (defanged). Продакшн-версии — в дампах STIX 2.1 / MISP.

Тип	Значение	Контекст
SHA256	`a30747b76e582410903566c8fd2e50c56cb469f267af99e847eced2040132328`	Max_video.apk, пакет ru.k6owy6.gzqak2x, C2 2[.]27[.]22[.]130:8443. Реверс-инжиниринг проведён нами.
SHA256	`ff79b21c3c2199a8375dfcfea02819a7e525133fd2593a02da4ee098dc8540ef`	base.apk, тот же кластер, C2 31[.]76[.]10[.]34:8443 (VirusTotal).
SHA256	`2be922ac1177689d3155fc2d1b9196facc790c520103b7280fe28066f7aac65f`	Ещё один вариант приманки «Max_video.apk» (омограф-написание), тот же кластер.
Package	`ru.k6owy6.gzqak2x`	Проанализированная сборка, team=001.
Package	`ru.mgpwm.ocz75i7`	Сборка team=Bombo, оператор «Muertos 2.0» (по публичному источнику abuse-репорта).
C2 (ws/http)	`2[.]27[.]22[.]130:8443`	PLAY2GO INTERNATIONAL LIMITED (DE); C2 из проанализированного образца.
C2 (ws/http)	`31[.]76[.]10[.]34:8443`	PLAY2GO INTERNATIONAL LIMITED (DE); связано ≥112 файлов на VirusTotal.
C2 (ws/http)	`94[.]156[.]237[.]16:8443`	PLAY2GO INTERNATIONAL LIMITED (DE); упомянут в публичном abuse-репорте (team Bombo).
ASN	AS215439	PLAY2GO-NET — PLAY2GO INTERNATIONAL LIMITED.
Домен (лендинг)	`2026rupolice[.]vercel[.]app`	Фишинг-лендинг с явным русскоязычным таргетингом, хостинг Vercel.
Домен (лендинг)	`police2206work[.]vercel[.]app`	Фишинг-лендинг под «полицию», хостинг Vercel.
Домен (лендинг)	`policeonline2026[.]vercel[.]app`	Фишинг-лендинг под «полицию» (опечатка в написании «online»), хостинг Vercel.

Домен (лендинг)	`policeonline2026[.]vercel[.]app`	Ещё один вариант написания того же лендинга.
Домен (лендинг)	`policecontrol2026[.]vercel[.]app`	Фишинг-лендинг под «полицию», хостинг Vercel.

6.1. MITRE ATT&CK

- T1660 — Phishing (мобильный вектор)
- T1204.002 — User Execution: Malicious File
- T1406 — Obfuscated Files or Information (подделка ZIP-флагов манифеста)
- T1417 — Input Capture (PIN-gate overlay)
- T1517 — Access Notifications (NotificationListenerService)
- T1582 — SMS Control
- T1636.003 — Protected User Data: Contact List
- T1636.004 — Protected User Data: SMS Messages
- T1481.002 — Web Service: Bidirectional Communication
- T1646 — Exfiltration Over C2 Channel
- T1541 — Foreground Persistence
- T1624 — Event Triggered Execution

7. Рекомендации

- Заблокировать перечисленные C2-адреса и подсеть 31.76.10.0/24 на периметровых средствах защиты; сообщить о злоупотреблении хостинг-провайдеру PLAY2GO INTERNATIONAL LIMITED и регистратору Vercel-поддоменов.
- Банкам из целевого списка — учитывать данный кластер при мониторинге фрод-паттернов (внезапная смена устройства перед транзакцией, координация по времени с получением push/SMS-кода).
- Пользователям — не устанавливать APK-файлы вне официальных магазинов приложений по ссылкам из мессенджеров и звонков с представлением «сотрудник правоохранительных органов/банка»; официальные приложения банков и MAX распространяются только через официальные магазины.
- Операторам средств автоматического анализа вредоносного ПО — учитывать описанный приём подмены флага «strong encryption» в локальном заголовке ZIP как индикатор целенаправленного обхода статических парсеров APK.
- Учитывая multi-tenant природу платформы «zloy», ожидать появления новых кластеров инфраструктуры с иными IP/пакетами при сохранении того же протокола C2 и паттернов эксфильтрации через Telegram.

TLP:CLEAR — Этот документ может распространяться без ограничений.